WannaCry

BEGIN Florian
XIA David

Qu’est-ce que Wannacry ?

- Attaque RansomWare massive
- 1ère version : 12 Mai 2017
- Mails piégés
- Chiffre les données du disque dur
- Exploit “Eternal Blue”



Qu’est ce qu’un RansomWare

- Prise d’otage des données personnelles
  - Chiffrement des données
- Demande d’une rançon
  - 300$ puis 600$ dans le cas de WannaCry
- Déroulement de l’attaque :
  - Pénétrer dans le système (Email malicieux)
  - Exécuter son payload
  - Chiffrer les données



Le commencement de l’attaque WannaCry

- Première infection en Espagne ou aux Royaume-Uni
  - Répandu dans le reste du monde en quelques heures
  - ~100 000 ordinateurs infectés la première nuit
  - ~230 000 en un jour dans plus de 150 pays

- Se répand automatiquement
  - Envoie de mails frauduleux pour envoyer le “code de transport”
  - Le code de transport scan pour trouver des cibles vulnérables
  - Utilisation de la faille Eternal Blue pour gagner un accès
  - Utilisation de la faille DoublePulsar pour s’installer / s'exécuter et se copier

Les ordinateurs infectés

- Une certaines mise à jour de sécurité non faites : MS17-010
  - Windows XP n'a pas reçu ce patch : Ces ordinateurs étaient donc théoriquement à plus haut risque

- Cependant :
  - Le payload ne fonctionne pas sur les ordinateurs Windows XP
    - L'exploit doit donc être lancé manuellement

- 98% des ordinateurs infectés : Windows 7
- Moins de 0.1% : Windows XP

La “résolution” du problème

- Ralentissement de la propagation du virus:
  - Enregistrement d’un nom de domaine faisant office de kill switch

- Mises à jour de sécurité publiée par Microsoft
  - Windows XP
  - Windows Server 2003
  - Windows 8

Les potentiels responsables

- Metadata du fichier de langage
  - Le PC ayant créé le malware était en UTC+9 : La Corée
- Kaspersky Lab et Symantec
  - Le code présente des similitudes avec d'autres provenant du Lazarus Group (Nord Coréen)

- La Corée du Nord serait la source de l'attaque
- Seulement des théories mais rien de sûr pour la cause de l'attaque

L’impact de WannaCry

- ~200 000 ordinateurs dans 150 pays
- Les 4 pays les plus affectés :
  - La Russie
  - L’Ukraine
  - L’Inde
  - Taiwan
- La plus grosse entreprise attaqué :
  - Les services de Santé Nationaux d’Angleterre et d’Écosse
    - Plus de 70 000 ordinateurs
    - Des outils médicaux
- L’impact est jugé faible
  - Découverte du Kill Switch
  - Pas d’infrastructure critique ciblés / touchées

Éviter ce problème

- Effectuer les mises à jour de sécurité
- Ne pas mettre des ordinateurs / machines sensibles sur des réseaux connectés avec l'extérieur
- Utiliser les OS encore supportés